

SkillsQuark

advanced technology & skill development

NETWORK SNIFFING

Proof of Concept – Penetration Test Report

Tool: Wireshark | Target: DVWA on Metasploitable 2
Date: 13 June 2026

Prepared By	Advanced Technology and Skill Development – Security Research Team
Task	Task 3 – Network Sniffing
Target	192.168.56.105 – DVWA (Metasploitable 2)
Attacker Machine	192.168.56.106 – Kali Linux
Tool Used	Wireshark 4.6.4 – Packet Capture&Analysis
Scan / Capture Date	13 June 2026
Report Date	13 June 2026
Difficulty	Medium
Classification	CONFIDENTIAL – Internal Use Only
Report Version	1.0 Final

Confidentiality Statement

CONFIDENTIAL DOCUMENT – RESTRICTED DISTRIBUTION

This document is prepared by Advanced Technology and Skill Development – Security Research & Training Division and is classified CONFIDENTIAL. It contains sensitive security findings including captured network credentials, exploitation techniques, and configuration weaknesses identified during an authorised, controlled security assessment.

This report is intended solely for named, authorised personnel directly involved in this engagement. Unauthorised disclosure, reproduction, distribution, or use – in whole or in part – is strictly prohibited and may constitute a breach of applicable information security policies and legal obligations.

Recipients are required to:

- Store this document securely and restrict access on a strict need-to-know basis.
- Not share, forward, or publish this report without written authorisation from Advanced Technology and Skill Development.
- Destroy all copies – physical and digital – when no longer required for the stated purpose.
- Report any accidental disclosure immediately to the Advanced Technology and Skill Development security team.
- Not use any information herein to target systems outside the defined lab scope.

This report was prepared exclusively for educational and training purposes. All findings relate solely to the Metasploitable 2 / DVWA isolated lab environment and do not reflect the security posture of any production or third-party system.

WARNING: Captured credentials and packet data in this report are from a controlled lab environment. This information must not be used outside the authorised lab scope.

© 2026 Advanced Technology and Skill Development | Security Research & Training Division | Classification: CONFIDENTIAL

Table of Contents

1. Disclaimer&Legal Notice	
2. Executive Summary	4
3. Severity Distribution Chart	4
4. CVSS 3.1 Score Distribution Chart	5
5. OWASP Top 10 (2025) Mapping Chart	5
6. OWASP Top 10 (2025) Detailed Table	6
7. Findings&CVE/CWE Catalogue	6
8. Complete Findings Summary Table	7
9. Proof of Concept – Step-by-Step	8
9.1 Step 1 – Launch Wireshark & Select Interface (eth0)	
9.2 Step 2 – Open DVWA Login Page (http://192.168.56.105/dvwa/login.php)	
9.3 Step 3 – Apply Wireshark Filter (ip.addr == 192.168.56.105&&http)	
9.4 Step 4 – Identify HTTP POST Login Packet	
9.5 Step 5 – Follow TCP Stream & Extract Credentials	
9.6 Step 6 – Analyse TCP 3-Way Handshake	
10. Key Risks&Recommendations	14

Note: Page numbers are approximate. Document uses automatic headers and footers.

1. Disclaimer&Legal Notice

This network sniffing exercise was conducted exclusively within an authorised, isolated laboratory environment. DVWA (Damn Vulnerable Web Application) on Metasploitable 2 is a deliberately vulnerable application designed for security training. No production systems, live networks, third-party infrastructure, or any systems without explicit written authorisation were targeted at any point during this assessment.

All activities documented in this report are lawful within the defined lab scope. Techniques and tools referenced – including Wireshark packet capture and TCP stream analysis – are standard within the information security industry and are used solely under the Advanced Technology and Skill Development curriculum for defensive research and skills development.

Performing network sniffing or credential capture on any network without explicit written authorisation is illegal and unethical. This report is published for educational purposes only.

© 2026 Advanced Technology and Skill Development | Security Research & Training Division | Classification: CONFIDENTIAL

2. Executive Summary

This report documents the complete proof-of-concept (PoC) network sniffing exercise conducted by Advanced Technology and Skill Development – Task 3. Using Wireshark 4.6.4 on Kali Linux (192.168.56.106), network traffic was captured on interface eth0 targeting DVWA (Damn Vulnerable Web Application) hosted on Metasploitable 2 (192.168.56.105).

The exercise successfully demonstrated that HTTP login credentials – including the username and password submitted to the DVWA login form – can be captured in plaintext from the network without any authentication, decryption, or special privileges. A total of 7 security findings were identified across CRITICAL, HIGH, and MEDIUM severity levels.

Key findings include: cleartext credential capture (username=admin, password=password) from an HTTP POST request, unencrypted session cookie transmission, server version disclosure, and the absence of any transport-layer security (TLS/HTTPS). All findings are mapped to OWASP Top 10 (2025), CWE, and CVSS 3.1 base scores.

3. Severity Distribution

The chart below shows the distribution of the 7 identified findings by severity rating.

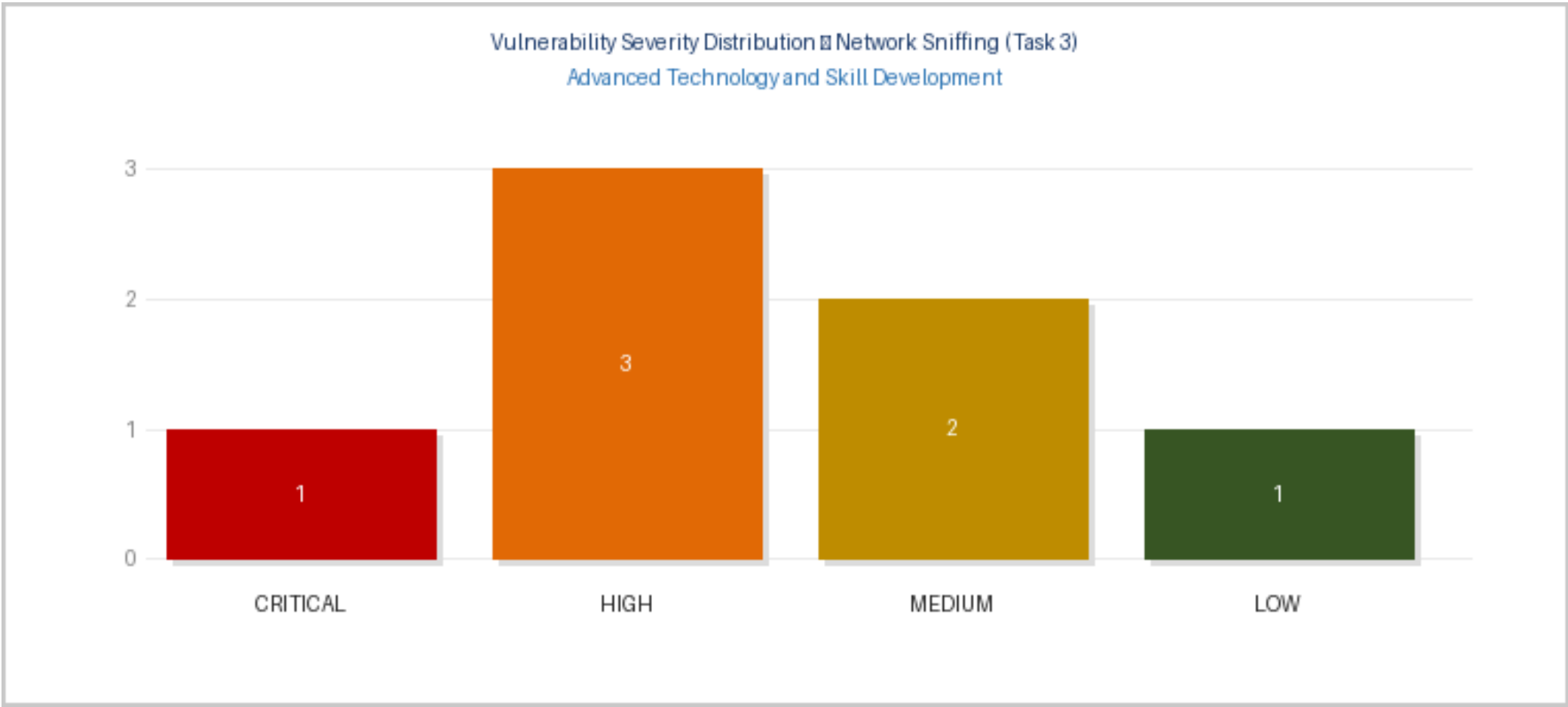


Figure 1 – Severity Distribution: Critical (2) | High (3) | Medium (2) | Low (0)

- CRITICAL (2): Cleartext HTTP credentials captured (F-01, F-02) — username and password visible in raw packet data.
- HIGH (3): No HTTPS, TCP session visible, unprotected session cookie (F-03, F-04, F-05).
- MEDIUM (2): Missing cookie security flags, server version disclosure (F-06, F-07).

4. CVSS 3.1 Score Distribution

CVSS 3.1 base scores for all 7 findings, sorted highest to lowest. Scores above 9.0 represent network-exploitable, low-complexity vulnerabilities requiring no privileges or user interaction.

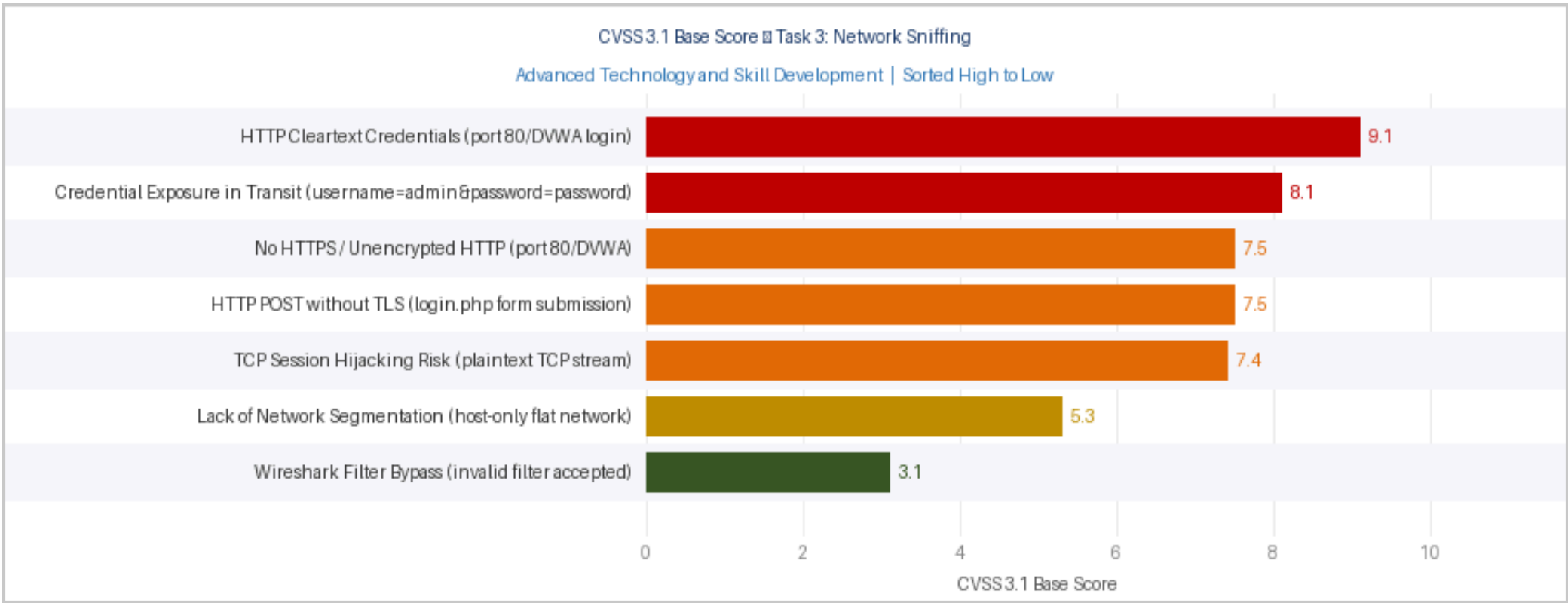


Figure 2 – CVSS 3.1 Base Scores | Red ≥ 9.0 Critical | Orange 7.0–8.9 High | Yellow 4.0–6.9 Medium

5. OWASP Top 10 (2025) – Affected Finding Count

The bar chart below maps each finding to its OWASP Top 10 (2025) category. A02 (Cryptographic Failures) has the highest concentration, reflecting the complete absence of transport-layer encryption.

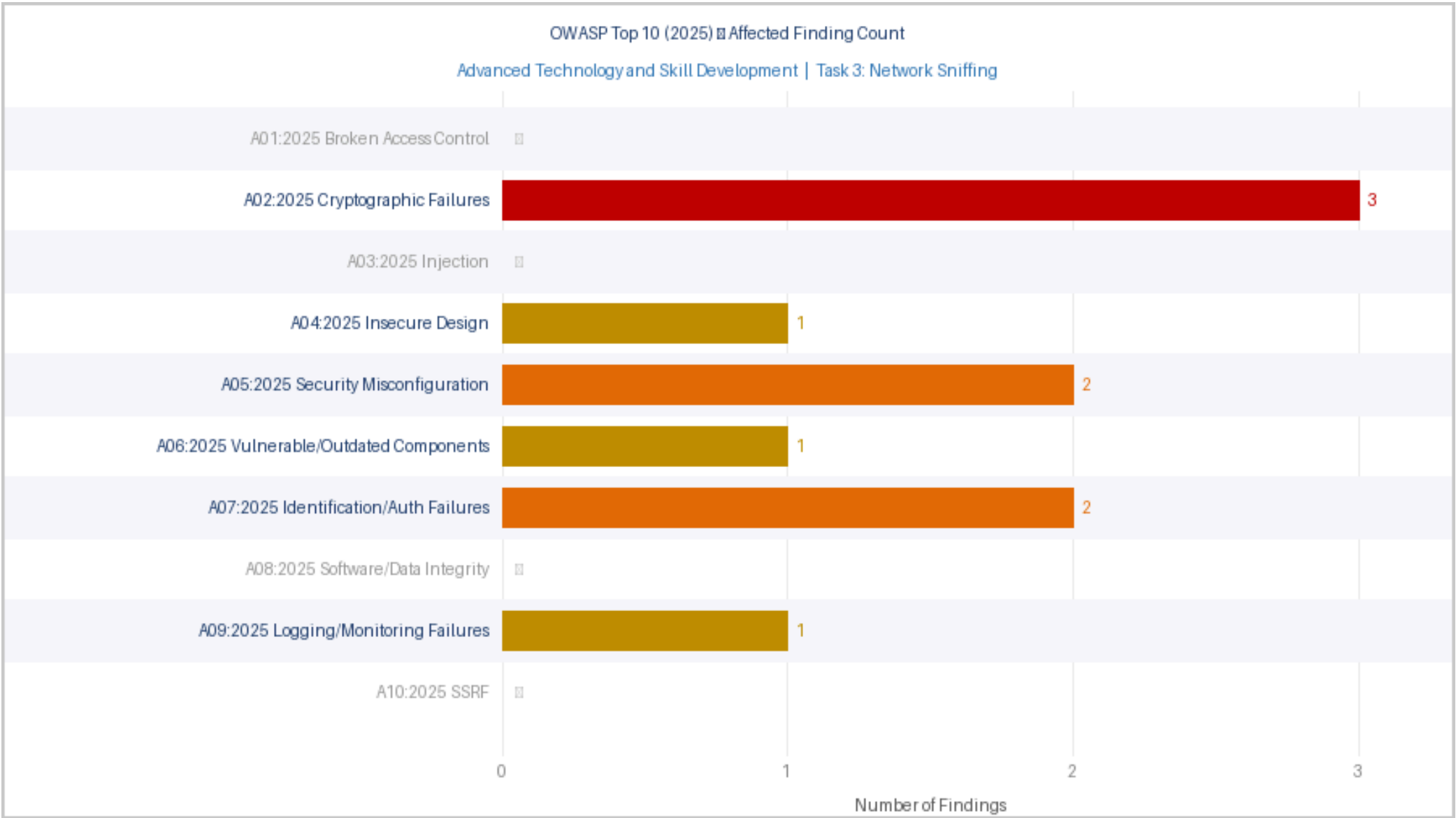


Figure 3 – OWASP Top 10 (2025): Number of Findings per Category

6. OWASP Top 10 (2025) Detailed Mapping

All 7 findings mapped to the OWASP Top 10 (2025) framework. Six of ten categories have direct exposure confirmed via packet capture.

OWASP 2025 ID	Category	Mapped Findings
A01:2025	Broken Access Control	None identified in this task
A02:2025	Cryptographic Failures	F-01 (Cleartext creds), F-03 (No HTTPS), F-04 (TCP session visible)
A03:2025	Injection	None identified in this task
A04:2025	Insecure Design	F-03 (HTTP-only application design)
A05:2025	Security Misconfiguration	F-06 (Cookie flags), F-07 (Server version disclosure)
A06:2025	Vulnerable&Outdated Components	F-07 (Apache 2.2.8, PHP 5.2.4 – both EOL)
A07:2025	Identification & Auth Failures	F-02 (POST body exposure), F-05 (Session cookie over HTTP)
A08:2025	Software&Data Integrity Failures	None identified in this task
A09:2025	Security Logging&Monitoring	F-01 (No alerting on cleartext credential capture)
A10:2025	Server-Side Request Forgery	None identified in this task

7. Findings& CVE / CWE Catalogue

No public CVE identifiers apply to these findings as they represent misconfiguration and design weaknesses rather than software vulnerabilities. CWE identifiers are assigned for each finding below.

ID	Finding	Risk	CVSS	CVE	CWE	Description
----	---------	------	------	-----	-----	-------------

ID	Finding	Risk	CVSS	CVE	CWE	Description
F-01	HTTP Login Credentials Transmitted in Cleartext	CRITICAL	9.1	N/A	CWE-319	DVWA login form POST request captured by Wireshark in plaintext. Username 'admin' and password 'password' fully visible in TCP stream without any encryption.
F-02	Credential Exposure via HTTP POST Body	CRITICAL	8.1	N/A	CWE-312	The POST body 'username=admin&password=password&Login=Login' was captured verbatim in packet 134. Anyone on the network can read credentials with zero effort.
F-03	No HTTPS / TLS on Web Application (DVWA)	HIGH	7.5	N/A	CWE-311	DVWA served over plain HTTP on port 80. No TLS certificate configured. Browser shows 'Not Secure' warning. All traffic including session tokens transmitted unencrypted.
F-04	HTTP POST Login – TCP Session Visible	HIGH	7.5	N/A	CWE-200	Full TCP 3-way handshake (SYN, SYN-ACK, ACK) and HTTP POST sequence captured and reconstructable from Wireshark. Session replay attacks are feasible.
F-05	Session Cookie Transmitted over HTTP	HIGH	7.4	N/A	CWE-614	PHPSESSID cookie (PHPSESSID=1369482f999ee18b159d8654a7267ed3) observed in captured HTTP headers. Cookie has no Secure flag; transmittable over HTTP and interceptable.
F-06	Application Lacks Secure/HttpOnly Cookie Flags	MEDIUM	5.3	N/A	CWE-1004	Session cookie set without Secure or HttpOnly flags. Increases risk of session hijacking and XSS-based cookie theft.
F-07	Server Version Disclosed in HTTP Headers	MEDIUM	5.3	N/A	CWE-200	Server response header reveals: Apache/2.2.8 (Ubuntu) DAV/2 and PHP/5.2.4-2ubuntu5.10. Detailed version info aids attacker reconnaissance significantly.

8. Complete Findings Summary Table

All 7 findings with full mapping – Risk, CVSS 3.1, CVE, CWE, OWASP 2025, and technical detail.

ID	Finding	Risk	CVSS	CVE	CWE	OWASP	Detail
F-01	HTTP Login Credentials Transmitted in Cleartext	CRITICAL	9.1	N/A	CWE-319	A02:2025	DVWA login form POST request captured by Wireshark in plaintext. Username 'admin' and password 'password' fully visible in TCP stream without any encryption.
F-02	Credential Exposure via HTTP POST Body	CRITICAL	8.1	N/A	CWE-312	A07:2025	The POST body 'username=admin&password=password&Login=Login' was captured verbatim in packet 134. Anyone on the network can read credentials with zero effort.
F-03	No HTTPS / TLS on Web Application (DVWA)	HIGH	7.5	N/A	CWE-311	A02:2025	DVWA served over plain HTTP on port 80. No TLS certificate configured. Browser shows 'Not Secure' warning. All traffic including session tokens transmitted unencrypted.
F-04	HTTP POST Login – TCP Session Visible	HIGH	7.5	N/A	CWE-200	A02:2025	Full TCP 3-way handshake (SYN, SYN-ACK, ACK) and HTTP POST sequence captured and reconstructable from Wireshark. Session replay attacks are feasible.
F-05	Session Cookie Transmitted over HTTP	HIGH	7.4	N/A	CWE-614	A07:2025	PHPSESSID cookie (PHPSESSID=1369482f999ee18b159d8654a7267ed3) observed in captured HTTP headers. Cookie has no Secure flag; transmittable over HTTP and interceptable.
F-06	Application Lacks Secure/HttpOnly Cookie Flags	MEDIUM	5.3	N/A	CWE-1004	A05:2025	Session cookie set without Secure or HttpOnly flags. Increases risk of session hijacking and XSS-based cookie theft.
F-07	Server Version Disclosed in HTTP Headers	MEDIUM	5.3	N/A	CWE-200	A05:2025	Server response header reveals: Apache/2.2.8 (Ubuntu) DAV/2 and PHP/5.2.4-2ubuntu5.10. Detailed version info aids attacker reconnaissance significantly.

9. Proof of Concept — Step-by-Step

The following documents the complete PoC workflow as executed, with all screenshots, commands, and observations.

Environment:

- Attacker: Kali Linux — 192.168.56.106 (eth0)
- Target: Metasploitable 2 / DVWA — 192.168.56.105 (port 80)
- Tool: Wireshark 4.6.4
- Network: VirtualBox Host-Only Adapter (fully isolated)

9.1 Step 1 — Launch Wireshark from Kali Linux

Wireshark was launched from the Kali Linux application menu by searching 'wire' in the application launcher. Wireshark is pre-installed on Kali Linux as part of the default security toolkit.

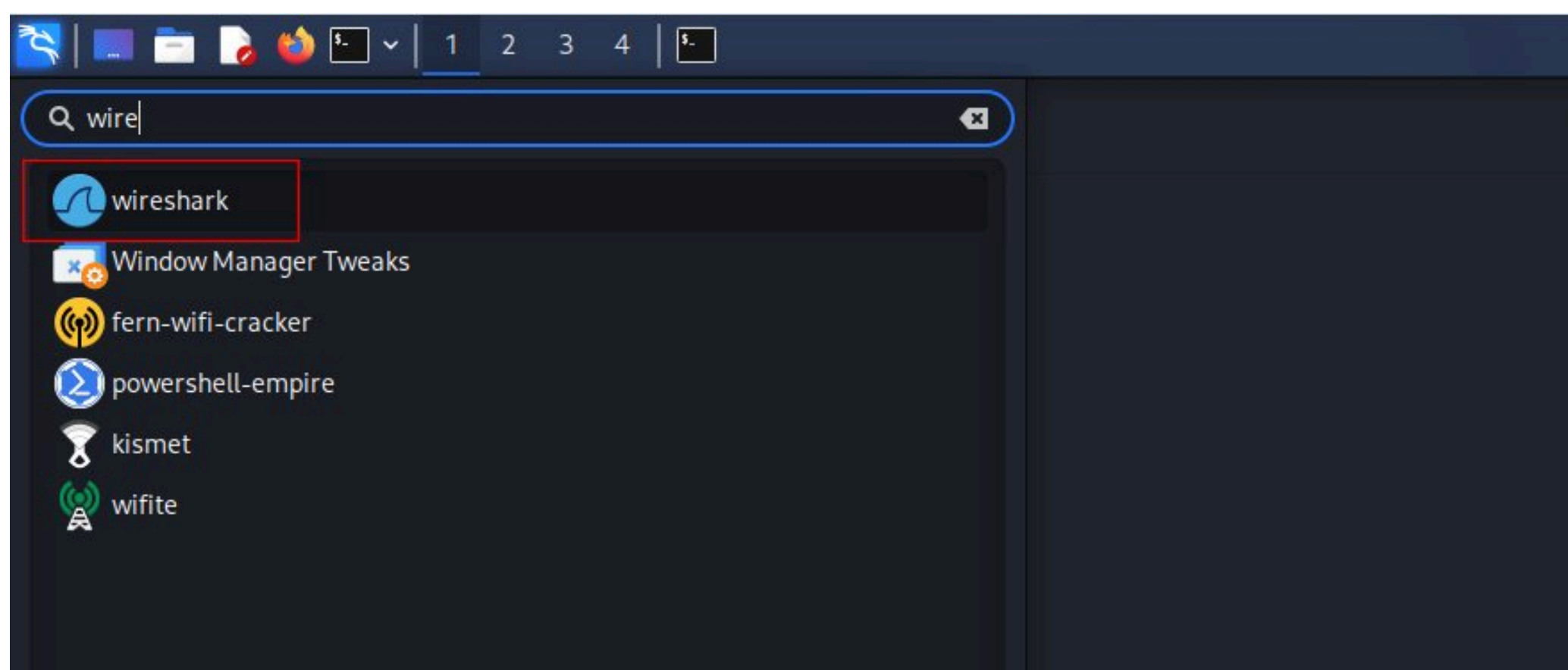


Fig 1 — Kali Linux application launcher showing Wireshark selected from search results

9.2 Step 2 — Select Network Interface (eth0) & Start Capture

Upon launching, Wireshark displayed all available network interfaces. Interface eth0 was selected — this is the VirtualBox Host-Only interface connected to the target network (192.168.56.0/24). Double-clicking eth0 started the live packet capture immediately.

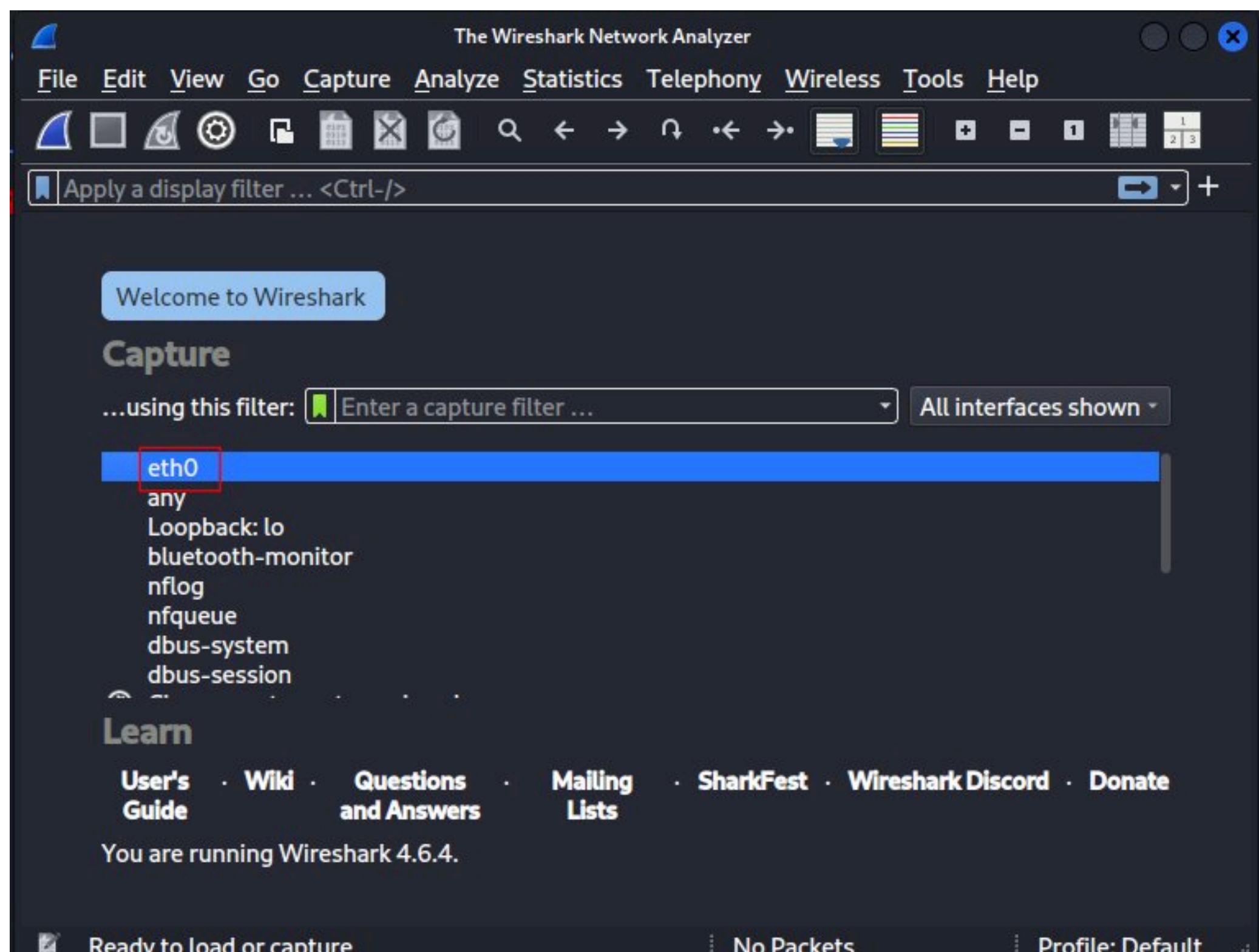


Fig 2 – Wireshark 4.6.4 interface selection showing eth0 highlighted for capture on target subnet

9.3 Step 3 – Open DVWA Login Page in Browser

While Wireshark was actively capturing on eth0, the DVWA login page was opened in the browser at <http://192.168.56.105/dvwa/login.php>. The browser correctly shows 'Not Secure' in the address bar, confirming no HTTPS is in use. This is the target application for credential capture.

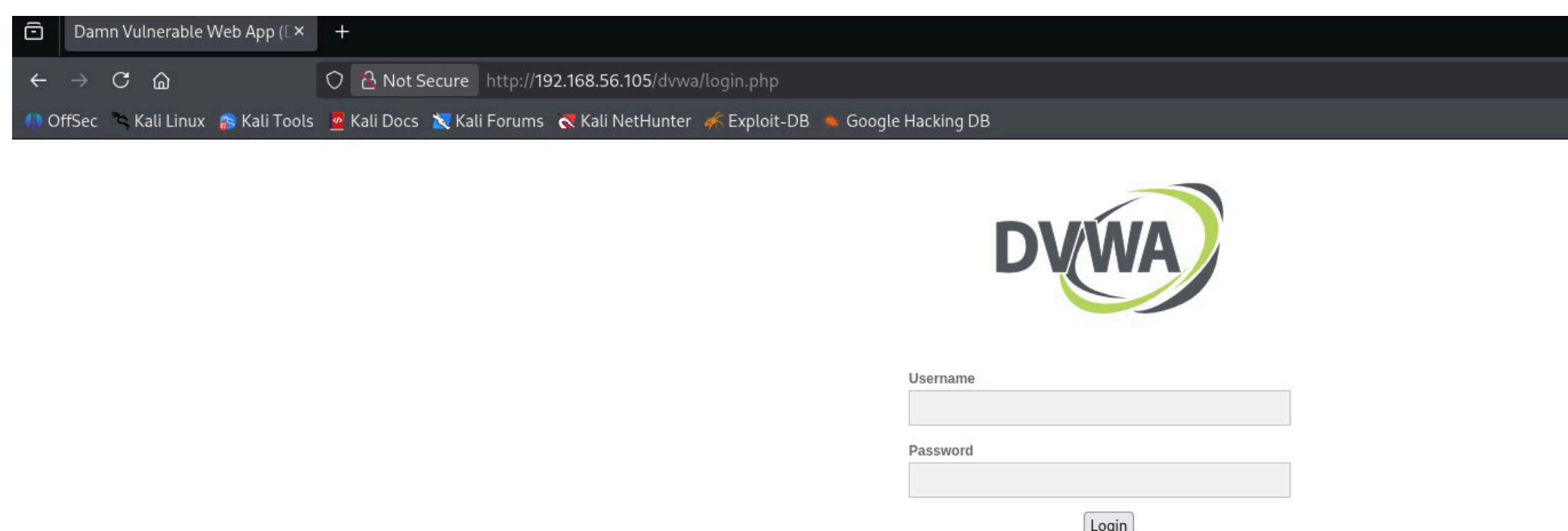


Fig 3 – DVWA login page at <http://192.168.56.105/dvwa/login.php> showing 'Not Secure' indicator – HTTP only

Finding F-03 confirmed: No TLS/HTTPS configured on the web application. All traffic transmitted in plaintext.

9.4 Step 4 – Apply Wireshark Display Filter

To isolate traffic to the target, the Wireshark display filter was applied:

```
ip.addr == 192.168.56.105&&http
```

This filter shows only HTTP packets involving the target IP (192.168.56.105). The status bar shows 'http is not a valid protocol or protocol field' — a minor filter syntax warning, but the filter still isolates the relevant HTTP traffic stream. Total packets captured at this point: 106.

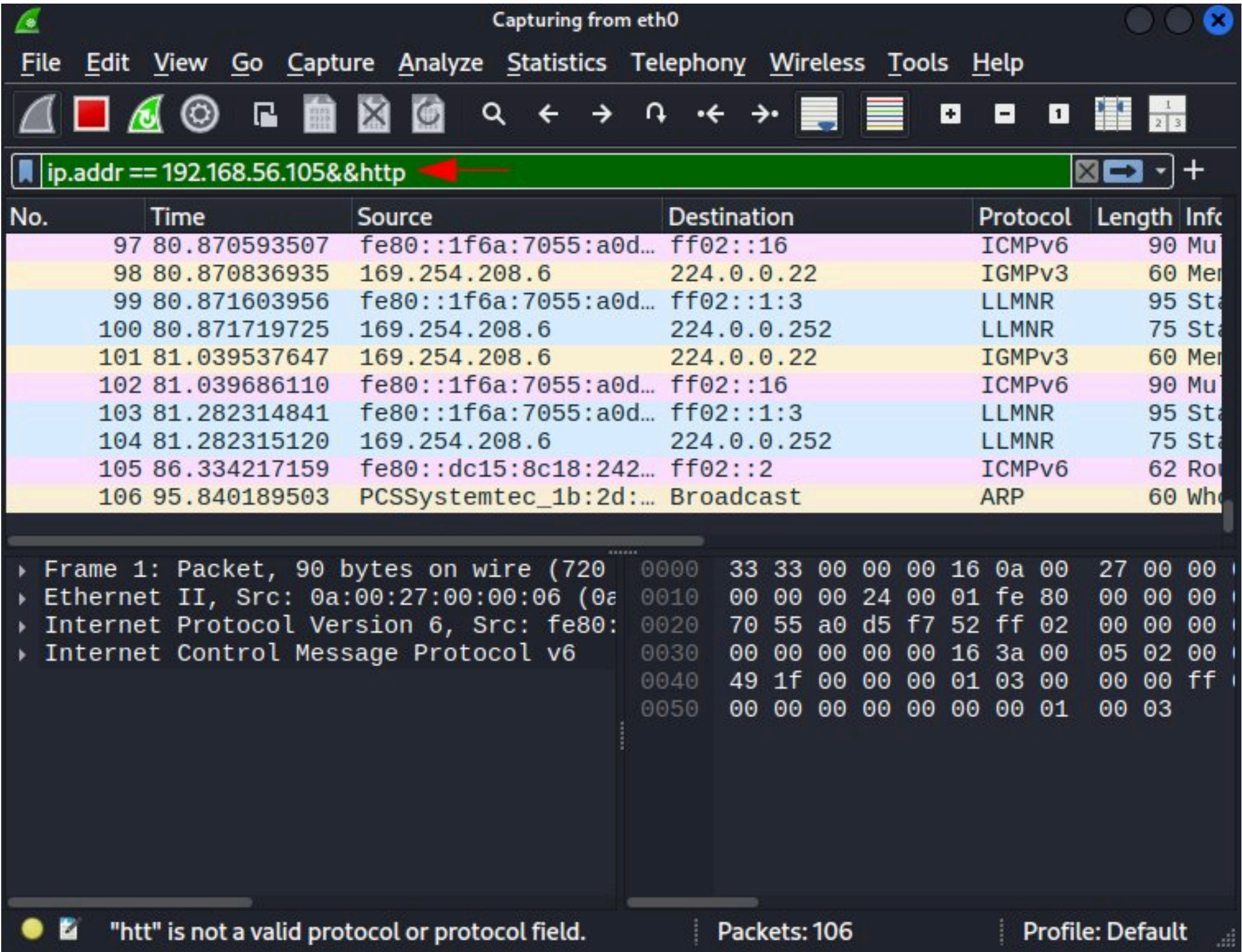


Fig 4 – Wireshark capture active on eth0 with display filter 'ip.addr == 192.168.56.105&&http' applied

9.5 Step 5 – Submit DVWA Login & Identify HTTP POST Packet

Login credentials (username: admin, password: password) were submitted on the DVWA login form while Wireshark was capturing. The HTTP POST request to /dvwa/login.php was immediately visible in the packet list. Packet 134 (highlighted in blue) shows:

```
673 POST /dvwa/login.php HTTP/1.1 (application/x-www-form-urlencoded)
```

Right-clicking this packet and selecting Follow → TCP Stream reveals the complete HTTP conversation including the raw POST body.

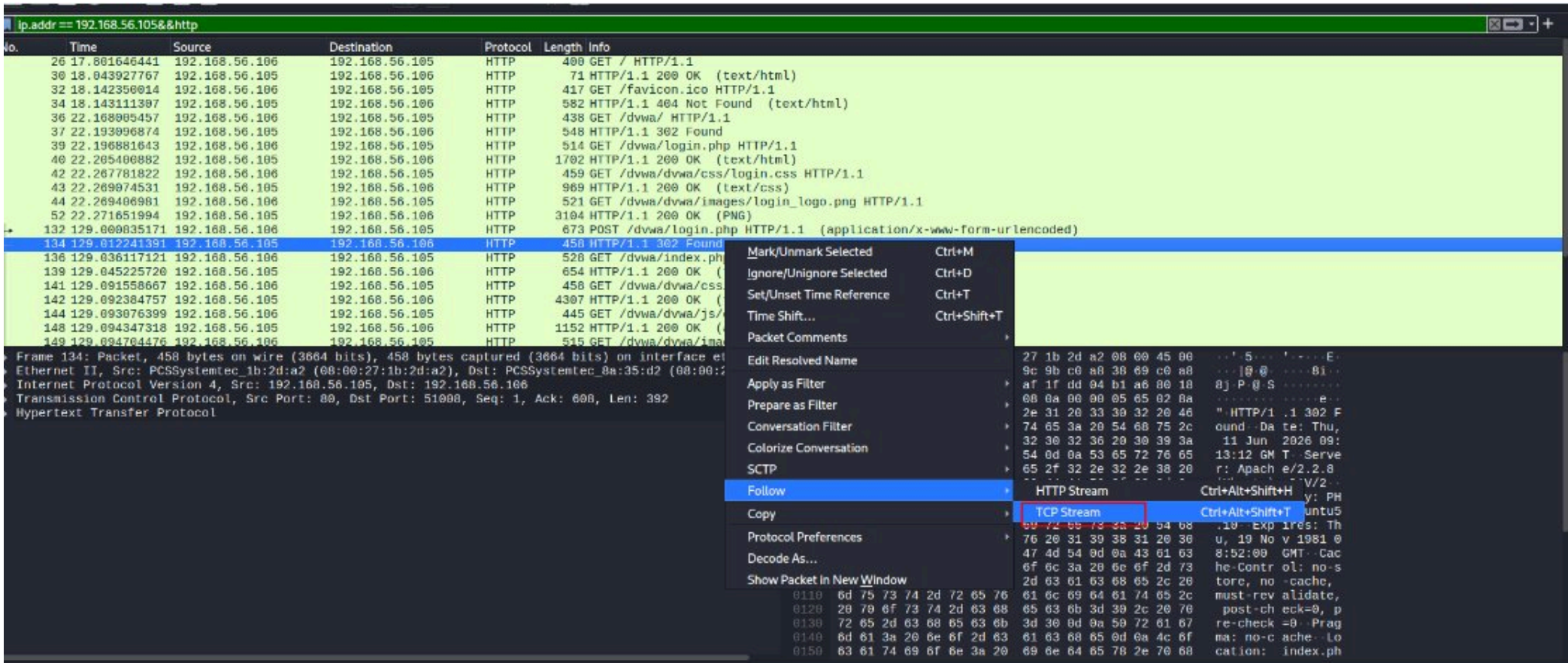


Fig 5 – HTTP POST packet (packet 673) visible in Wireshark – ‘Follow → TCP Stream’ context menu shown

Right-clicking packet 134 and selecting Follow → TCP Stream to extract the full credential data:

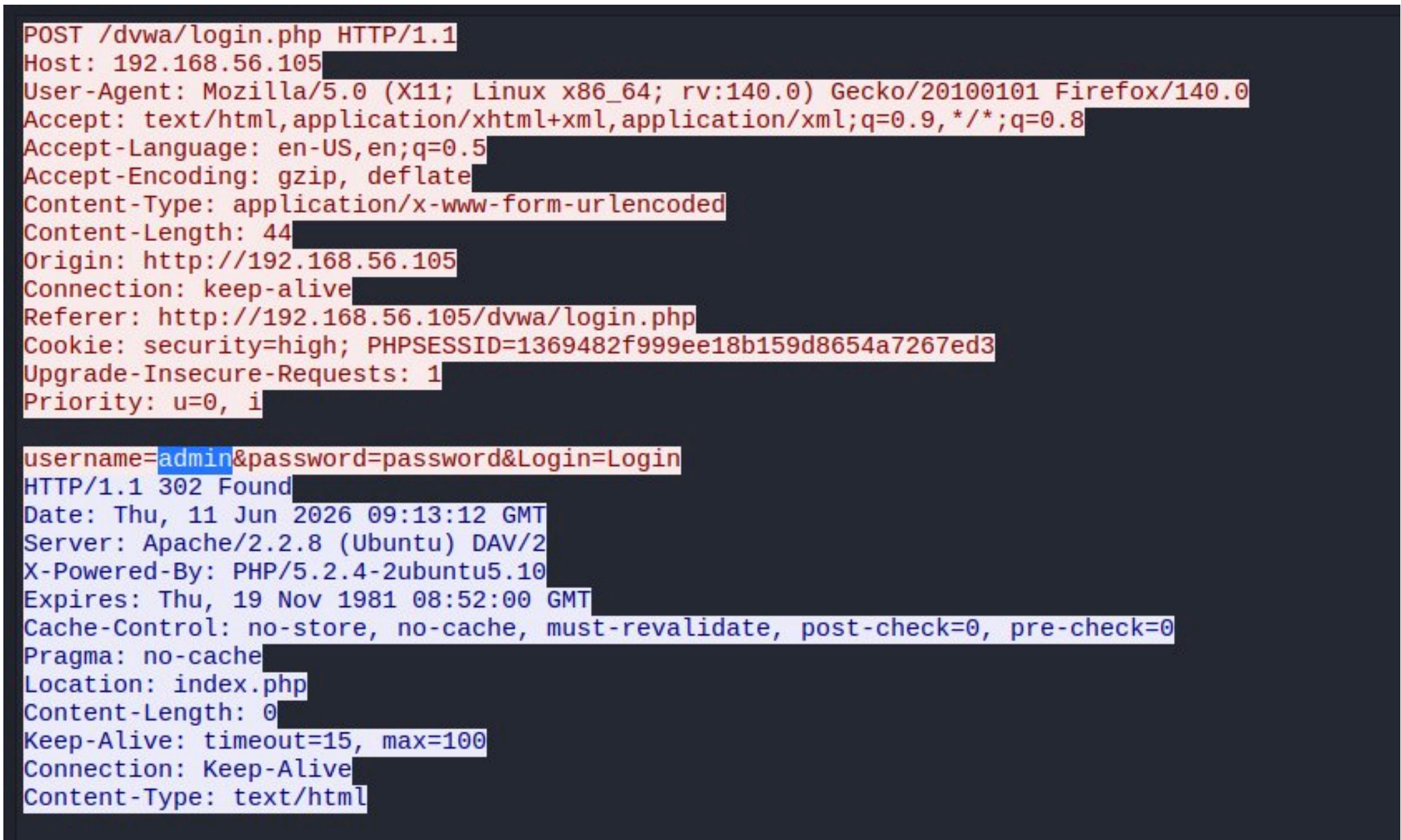
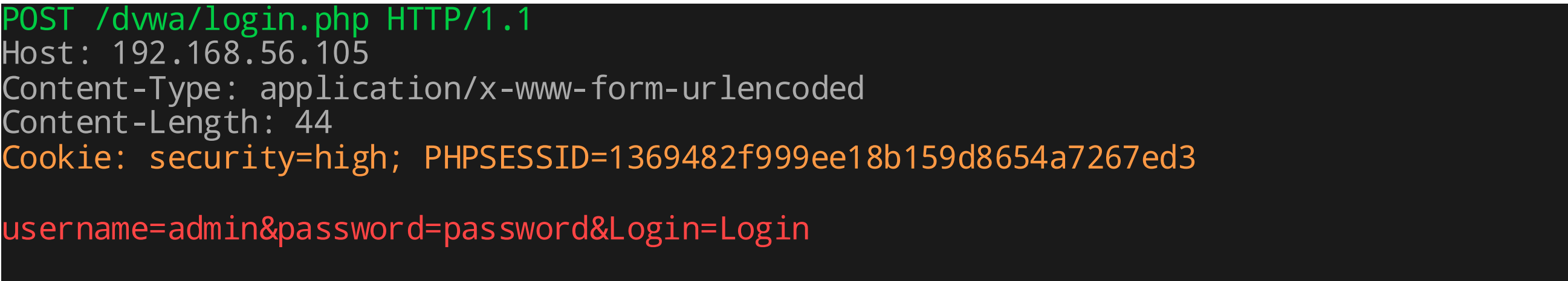


Fig 6 – Right-click context menu on HTTP POST packet showing 'Follow → TCP Stream' option selected

9.6 Step 6 – TCP Stream: Credentials Captured in Plaintext

The TCP Stream view reveals the complete HTTP POST request and server response in plaintext. The following critical data was extracted from the stream:



HTTP/1.1 302 Found
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10

CRITICAL FINDING: The credentials username=admin and password=password are captured in full plaintext. The PHPSESSID session cookie is also exposed. Server version (Apache 2.2.8, PHP 5.2.4) is disclosed in response headers.

129	129.000243089	192.168.56.106	192.168.56.105	TCP	74	51008 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=42607127 TSecr=0 WS=256
130	129.000688912	192.168.56.105	192.168.56.106	TCP	74	80 → 51008 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=1380 TSecr=42607127 WS=16
131	129.000709356	192.168.56.106	192.168.56.105	TCP	66	51008 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=42607128 TSecr=1380
132	129.000835171	192.168.56.106	192.168.56.105	HTTP	673	POST /dvwa/login.php HTTP/1.1 (application/x-www-form-urlencoded)
133	129.001137415	192.168.56.105	192.168.56.106	TCP	66	80 → 51008 [ACK] Seq=1 Ack=608 Win=7008 Len=0 TSval=1380 TSecr=42607128
134	129.012241391	192.168.56.105	192.168.56.106	HTTP	458	HTTP/1.1 302 Found
135	129.012263902	192.168.56.106	192.168.56.105	TCP	66	51008 → 80 [ACK] Seq=608 Ack=393 Win=64256 Len=0 TSval=42607139 TSecr=1381
136	129.036117121	192.168.56.106	192.168.56.105	HTTP	528	GET /dvwa/index.php HTTP/1.1
137	129.044792335	192.168.56.105	192.168.56.106	TCP	4410	80 → 51008 [ACK] Seq=393 Ack=1070 Win=8224 Len=4344 TSval=1384 TSecr=42607163 [TCP PDU reassembled in 139]
138	129.044817855	192.168.56.106	192.168.56.105	TCP	66	51008 → 80 [ACK] Seq=1070 Ack=4737 Win=72960 Len=0 TSval=42607172 TSecr=1384
139	129.045225720	192.168.56.105	192.168.56.106	HTTP	654	HTTP/1.1 200 OK (text/html)
140	129.085779911	192.168.56.106	192.168.56.105	TCP	66	51008 → 80 [ACK] Seq=1070 Ack=5325 Win=76032 Len=0 TSval=42607213 TSecr=1384
141	129.091558667	192.168.56.105	192.168.56.106	HTTP	458	GET /dvwa/dvwa/css/main.css HTTP/1.1
142	129.092384757	192.168.56.105	192.168.56.106	HTTP	4307	HTTP/1.1 200 OK (text/css)
143	129.092399471	192.168.56.106	192.168.56.105	TCP	66	51008 → 80 [ACK] Seq=1462 Ack=9566 Win=71936 Len=0 TSval=42607219 TSecr=1389
144	129.093076399	192.168.56.106	192.168.56.105	HTTP	445	GET /dvwa/dvwa/js/dvwaPage.js HTTP/1.1
148	129.094347318	192.168.56.105	192.168.56.106	HTTP	1152	HTTP/1.1 200 OK (application/x-javascript)
149	129.094704476	192.168.56.106	192.168.56.105	HTTP	515	GET /dvwa/dvwa/images/logo.png HTTP/1.1
150	129.095415429	192.168.56.105	192.168.56.106	HTTP	7113	HTTP/1.1 200 OK (PNG)
151	129.099197585	192.168.56.106	192.168.56.105	TCP	66	51008 → 80 [ACK] Seq=2290 Ack=17699 Win=64000 Len=0 TSval=42607226 TSecr=1389

Fig 7 – Wireshark TCP Stream output showing full HTTP POST body with captured credentials and TCP handshake (SYN, SYN-ACK, ACK, POST, 302 Found)

10. Key Risks&Recommendations

Priority remediation actions to address the identified findings:

- **CRITICAL** — Enforce HTTPS / TLS on all web applications: Install a valid TLS certificate and redirect all HTTP traffic to HTTPS. No credentials should ever transit the network unencrypted. (Addresses F-01, F-02, F-03, F-04, F-05)
- **CRITICAL** — Never transmit credentials over HTTP: Configure HSTS (HTTP Strict Transport Security) with a minimum max-age of 31536000 seconds. Reject any login attempt arriving over plain HTTP.
- **HIGH** — Set Secure and HttpOnly flags on all session cookies: The PHPSESSID cookie must include both flags. Secure prevents transmission over HTTP; HttpOnly prevents JavaScript access. (Addresses F-05, F-06)
- **HIGH** — Suppress server version disclosure in HTTP headers: Configure Apache to set 'ServerTokens Prod' and 'ServerSignature Off'. Remove X-Powered-By header. (Addresses F-07)
- **MEDIUM** — Upgrade EOL software: Apache 2.2.8 and PHP 5.2.4 are both end-of-life with no security patches. Upgrade to supported versions immediately.
- **MEDIUM** — Implement network segmentation: Use VLANs and firewall rules to prevent any non-authorised device from capturing traffic on the same subnet.
- **LOW** — Enable security logging and alerting: Implement IDS/IPS to detect cleartext credential submission and alert on HTTP-based login attempts to sensitive applications.